

OSINT & Reconnaissance — POC Report

Intern Name: Ruby Kannaujiya

Intern ID: 309

Tool Name / Topic

Open-Source Intelligence (OSINT) & Reconnaissance — tools: whois, dig, theHarvester, amass, sublist3r, shodan, crt.sh, Google Dorking, wayback, recon-ng, Maltego.

History

OSINT has long been used by investigators, journalists, and security researchers to gather publicly available information. With the growth of the web, social media, and cloud services, OSINT techniques have become central to profiling targets for security assessments, red-team operations, and incident response. Modern OSINT toolkits combine DNS discovery, certificate transparency, web archives, social sites, and search engines.

Description

OSINT/Recon is the systematic collection of publicly available information about a target (domain, company, person) to build an intelligence profile. In security testing, recon identifies attack surface (subdomains, exposed services, employee emails) to plan further assessment. This POC shows ethical, legal OSINT performed in a lab/consented environment.

Legal / Ethical Note: Only perform recon against targets you own, have explicit permission to test, or public research targets where allowed by law. Do NOT use these techniques for harassment, unauthorized access, or unlawful activity.

What Is This Topic About?

- Collecting domain and infrastructure details (DNS, subdomains, certificates).
- Gathering employee and organizational footprints (emails, LinkedIn, job posts).
- Discovering historical content (Wayback Machine) and publicly leaked data.
- Building an attack surface map for authorized security assessments.

Key Characteristics / Features

- Passive (do not interact with target systems) and active (direct queries, scans) recon.
- Uses public records, search engines, certificate transparency logs, social media.
- Highly automatable and scriptable.
- Produces actionable outputs: subdomain lists, IPs, open services, personnel info.
- Useful for threat modeling and scoping penetration tests.

Types / Modules / Tools Covered

- **Domain Info:** whois, dig, nslookup
- **Subdomain Discovery:** amass, sublist3r, assetfinder
- **Certificate/CT Logs:** crt.sh, certspotter
- **Email/Employee Harvesting:** theHarvester, LinkedIn, Hunter.io
- **Service Discovery:** shodan, Censys (passive)
- **Historical Content:** Wayback Machine (web.archive.org)
- **Recon Frameworks:** recon-ng, Maltego
- **Search Engine Dorking:** Google Dorks (site:, inurl:, filetype:)

- **Reverse IP/ASN:** viewdns, ipinfo, whois for ASN lookups

How Will This Help?

- Reveal attack surface and exposed assets before active testing.
- Identify likely employee targets for phishing simulations (authorized only).
- Discover misconfigured services and expired certificates.
- Build a prioritized list of assets for security assessment.

Detailed POC — Step-by-step (practical, safe, and repeatable)

Target for PoC: targetdomain.com (use your own domain or an authorized target).
Replace targetdomain.com below with the domain you have permission to test.

A. Passive Recon — Domain & DNS

1. WHOIS lookup

```
whois targetdomain.com
```

- **What to capture:** Registrar, registration date, expiry, name servers, registrant contacts (if public).

2. DNS Info (dig)

```
dig targetdomain.com any +noall +answer  
dig targetdomain.com A +short  
dig targetdomain.com MX +short  
dig targetdomain.com TXT +short
```

- **What to capture:** A records, MX (mail), TXT (SPF/DKIM), name servers.

3. Reverse DNS / Zone transfers (passive check first)

```
dig AXFR @ns1.targetdomain.com targetdomain.com
```

- **Note:** AXFR will usually be refused; if allowed, you found a misconfigured zone transfer — treat as sensitive and report only to owner.

B. Subdomain Discovery (enumeration)

1. amass (passive + active)

```
amass enum -passive -d targetdomain.com -o amass_passive.txt  
amass enum -active -d targetdomain.com -o amass_active.txt
```

2. sublist3r

```
sublist3r -d targetdomain.com -o sublist3r.txt
```

3. crt.sh (certificate transparency)

- Visit: <https://crt.sh/?q=%25.targetdomain.com> or script:

```
curl -s "https://crt.sh/?q=%25.targetdomain.com&output=json" | jq  
'.[].name_value' | sort -u
```

- **What to capture:** Subdomains from issued certs (often includes wildcard certs, staging hosts).

4. Combine and deduplicate

```
cat amass_passive.txt amass_active.txt sublist3r.txt | sort -u >  
subdomains_all.txt
```

C. IP & ASN Discovery

1. Resolve subdomains to IPs

```
cat subdomains_all.txt | xargs -n1 -P10 -I% sh -c 'dig +short % | sed  
"s/$/ %/' > subdomains_ips.txt
```

2. ASN lookup

```
# for each IP
whois 1.2.3.4 | grep -E 'origin|AS' -m1
ipinfo 1.2.3.4
```

- **What to capture:** Shared hosting, CDNs, or own ASN.

D. Exposed Services (passive & responsible active)

1. Shodan / Censys (passive)

- Search queries:
 - Shodan: `hostname:targetdomain.com`
 - Censys: use web UI or API
- **What to capture:** Exposed services, open ports, banners, device types.
- 2. **Passive versus active scan note:** Do not run aggressive port scans without permission. For authorized testing, use nmap limited scope:

```
nmap -sV -Pn -p 80,443,22 <ip> -oN nmap_target.txt
```

E. Email & People Harvesting

1. theHarvester

```
theHarvester -d targetdomain.com -b google -l 200 -f theharvester.html
```

2. LinkedIn searches

- Google dork: `site:linkedin.com/in "Target Company"`
- Capture publicly listed employees, titles, locations.

3. Hunter.io (domain search)

- Use API or web: https://api.hunter.io/v2/domain-search?domain=targetdomain.com&api_key=APIKEY

F. Web Content & Historical Recon

1. Wayback Machine

- Visit https://web.archive.org/web/*/https://targetdomain.com/*

- Capture historical pages, past exposed endpoints, backup files.

2. Google Dorking examples

site:targetdomain.com filetype:pdf

site:targetdomain.com inurl:backup

site:targetdomain.com "password"

- **What to capture:** Exposed docs, configs, credentials accidentally published.

G. Configuration & Certificate Checks

1. SSL Labs

- Use <https://www.ssllabs.com/ssltest/analyze.html?d=targetdomain.com> to check TLS config.
- 2. **Check HSTS, CSP, secure headers** via `curl -I https://targetdomain.com`

H. Build Recon Report (output)

- subdomains_all.txt (unique list)
- subdomains_ips.txt (resolved IPs)
- services.txt (Shodan/Censys/nmap findings)
- emails.csv (harvested emails)
- whois.txt (registrar data)
- wayback-links.txt (interesting historical pages)
- dorks-results/ (downloaded public PDFs or screenshots — only if allowed to store)

PoC Images (placeholders — add your screenshots)

- whois terminal output screenshot
- amass enumeration terminal output
- crt.sh results screenshot showing subdomains
- theHarvester results screenshot with emails
- Wayback snapshot showing an exposed page

- Shodan result screenshot for an exposed service



15-Liner Summary

1. Start passive: whois, dig, crt.sh.
2. Enumerate subdomains: amass, sublist3r.
3. Resolve subdomains to IPs and ASNs.
4. Use Shodan/Censys for passive service discovery.
5. Harvest emails with theHarvester and LinkedIn.
6. Check historical content in Wayback.
7. Google Dork for exposed files (pdf, xls, backup).
8. Use SSL Labs for TLS config issues.
9. Combine outputs into structured lists.
10. Prioritize targets for authorized testing.
11. Avoid intrusive scans unless permitted.
12. Document every source and timestamp.
13. Map findings to risk (public sensitive docs first).
14. Share only with stakeholders; redact sensitive third-party data.
15. Maintain an ethical/legal log of actions.



Time to Use / Best Case Scenarios

- Pre-engagement reconnaissance before pen-test (with permission).
- Threat intelligence collection on suspected phishing campaigns.
- Brand monitoring for leaked credentials or sensitive documents.
- Red-team planning and social-engineering awareness exercises.



When to Use During Investigation

- After suspicious email campaigns (identify sender infrastructure).
- To validate reported data leaks.

- To enumerate exposed assets after a breach.
- During tabletop exercises to build scenarios.



Best Person to Use & Required Skills

User: Threat Intelligence Analyst / Pentester / SOC Analyst / Forensic Researcher

Skills:

- Comfortable with Linux CLI and scripting (bash, Python).
- Familiar with DNS, TLS, HTTP basics.
- Knowledge of social media and OSINT ethics.
- Ability to analyze large lists and triage findings.



Flaws / Suggestions to Improve

- Passive data may be stale or incomplete.
- False positives from certificate logs (test/staging hosts).
- Google Dork results can return third-party content that's irrelevant.
- Some services rate-limit/deny automated queries (API keys required).
- Over-collection of personal data raises privacy concerns — redact as needed.



Good About This Topic (Why Learn It)

- Low cost, high value — uses freely available data.
- Quickly builds a map of publicly exposed assets.
- Helps find easy wins (exposed PDFs, forgotten subdomains).
- Improves security posture by identifying privacy leaks.
- Great for beginner-to-advanced learning progression.



Remediation / Hardening Suggestions

- Remove sensitive PDFs and backups from public webroots.
- Harden DNS (disable zone transfers; use DNSSEC where possible).
- Rotate certificates and remove unused wildcard entries.
- Enforce least-public exposure for employee data; use privacy settings.
- Monitor certificate transparency logs and register notification alerts.
- Use robots.txt and secure directories properly (but do not rely on robots for security).
- Rate-limit or block abusive recon patterns; use WAF to mitigate scanning noise.